Cahier des charges

Informatisation d'une clinique de campagne

Version : v2

Présenté par le Groupe 11 :
Aminata YABRE (IOM)
Florian LATTARD (Cyber)
Pierre ENGELENDER (Cyber)
Bastien LAURENT (IOM)
Emile FREZZA (PilPro)

IUT Nord Franche-Comté - Université Marie & Louis Pasteur
BUT3 Réseaux & Télécommunications



1. Contexte et présentation de l'infrastructure

1.1. Contexte du projet

Le présent projet a pour objectif de concevoir l'architecture informatique d'une **clinique de campagne temporaire**, destinée à assurer la prise en charge de patients dans un contexte de déploiement rapide et avec des moyens matériels limités.

Le scénario retenu s'inspire, sur le plan organisationnel et visuel, des structures hospitalières temporaires mises en place lors de la crise sanitaire liée à la COVID-19, notamment de l'hôpital militaire déployé à Mulhouse en 2020. Cette référence constitue principalement un **cadre scénaristique** permettant de contextualiser le déploiement d'une infrastructure informatique temporaire. L'architecture proposée devra toutefois répondre aux contraintes propres au projet, notamment en matière de simplicité de déploiement, de continuité de service, de sécurité et de robustesse.

L'infrastructure informatique devra être conçue **à partir de zéro**, aucun réseau préexistant n'étant disponible sur le site. Elle devra ainsi permettre le fonctionnement de l'ensemble des services informatiques nécessaires à la clinique, tout en restant adaptée aux contraintes d'une installation temporaire et susceptible d'être déployée rapidement.

Une attention particulière sera portée à la **continuité de service et à la résilience de l'infrastructure**, afin de limiter l'impact d'une défaillance matérielle, réseau ou d'une perte de connectivité, il faudra mettre en place des vérifications périodiques pour s'assurer du bon fonctionnement des contre-mesures). La conception devra également intégrer des mesures permettant d'assurer un niveau de **robustesse face aux menaces de cybersécurité**, notamment du fait de la présence et du traitement de données médicales. Il faudra aussi s'assurer de mettre en place les patchs réglants les failles d'applications ou logiciels, faire du pentest pour vérifier le patch. Si anomalie faire remonter une alerte.

Le projet comprend également la réalisation d'un **dossier de conception** décrivant l'architecture retenue ainsi que les différents composants de l'infrastructure.

1.2. Organisation de la clinique

La clinique est dimensionnée pour accueillir jusqu'à **30 patients simultanément**, répartis dans trois grandes chambres de dix lits chacune.

L'établissement est organisé autour de **neuf tentes**, réparties de la manière suivante :

- une tente dédiée à l'accueil ;
- une tente dédiée aux fonctions administratives ;
- une tente dédiée à la garde et au repos du personnel ;
- trois tentes constituant les chambres, chacune disposant de dix lits ;
- trois tentes dédiées aux soins.

Les trois salles de soins sont considérées comme équivalentes du point de vue de leurs besoins informatiques.

Cette organisation constitue le périmètre physique de la clinique : **aucun autre espace n'est prévu dans le scénario**.

1.3. Utilisateurs et profils d'accès

L'infrastructure informatique est dimensionnée pour environ **50 utilisateurs informatiques simultanés**, principalement issus du personnel de la clinique. Les utilisateurs sont répartis en plusieurs profils correspondant à leurs fonctions et à leurs besoins d'accès au système d'information.

Les principaux profils identifiés sont les suivants :

- **Personnel médical** : médecins, infirmiers et aides-soignants. Ces utilisateurs doivent notamment pouvoir accéder aux informations nécessaires à la prise en charge des patients ;
- **Personnel administratif** : secrétaires médicales et personnels chargés des fonctions administratives, notamment de la gestion des entrées et sorties ainsi que de la facturation ;
- **Direction et fonctions support** : responsables de la clinique, personnel chargé de la gestion de l'établissement ainsi que les administrateurs des systèmes et réseaux. Ce profil regroupe les fonctions de pilotage, de gestion et d'administration informatique ;
- **Patients et visiteurs** : ces utilisateurs disposent d'un accès distinct au système d'information, limité à un réseau Wi-Fi invité permettant l'accès à Internet. Cet accès est isolé du reste de l'infrastructure et ne doit permettre aucune interaction avec les ressources internes de la clinique.

Les droits d'accès aux ressources informatiques devront ainsi être définis en fonction des profils et des responsabilités de chaque utilisateur, en particulier pour les ressources contenant des données médicales.

1.4. État initial et périmètre de l'infrastructure

La clinique étant une structure nouvellement déployée, **aucune infrastructure réseau n'est disponible à l'origine du projet**. La conception devra donc couvrir l'ensemble des composants nécessaires au fonctionnement du système d'information, notamment les infrastructures **LAN, WAN et Wi-Fi**, ainsi que les équipements informatiques et les serveurs nécessaires aux différents services.

Les applications et services de la clinique seront également développés dans le cadre du projet.

Le site de déploiement dispose de plusieurs possibilités d'accès aux réseaux des fournisseurs d'accès à Internet. Selon les infrastructures disponibles localement, une

connexion peut notamment être établie par fibre, réseau coaxial, réseau mobile 4G/5G ou liaison satellitaire.

L'ensemble de l'infrastructure devra donc être conçu pour répondre aux contraintes particulières d'une clinique temporaire : **déploiement à partir d'une infrastructure inexistante, ressources limitées, nécessité de continuité de service, protection des données médicales et maîtrise des accès aux ressources du système d'information**.



Photo présentant une tente d'une clinique de campagne

2. Définition des besoins en termes de services

Cette section exprime les services nécessaires. Que ce soit applicatifs, métiers, réseau et d'administration indispensables aux différents profils d'utilisateurs, tout en assurant un niveau de sécurité et de disponibilité adapté au contexte de la clinique.

Les services à mettre en place sont répartis en plusieurs catégories : gestion des données de santé et des activités métiers, administration et authentification, communication, partage de données, sécurité physique et réseau, sauvegarde et supervision.

Ces services devront chacun avoir leur serveurs qui seront isolés grâce à des machines virtuelles. Ces machines virtuelles seront hébergées sur un ou plusieurs hyperviseurs pour un cloisonnement plus important. Il faudra qu'il héberge un minimum de 4 VM. Il faudra aussi mettre en place un second hyperviseur qui prendra le relai en failover.

2.1. Gestion applicative et métier

2.1.1. Gestion des données de santé

La clinique devra disposer de deux applications Web distinctes permettant de répondre aux besoins des fonctions médicales et administratives.

La première application sera dédiée au **Dossier Patient Informatisé (DPI)**. Elle permettra au personnel médical autorisé d'accéder aux informations nécessaires au suivi des patients et de les mettre à jour. L'application devra notamment permettre la consultation et la modification des fiches médicales ainsi que la gestion des documents associés au dossier du patient, tels que les examens et résultats de laboratoire.

La seconde application sera dédiée à la **Gestion Administrative du Patient (GAP)**. Elle permettra au personnel administratif de gérer les informations relatives au séjour des patients et à leur prise en charge administrative. Elle devra notamment permettre de suivre les admissions et sorties, l'affectation des patients aux chambres et aux lits, la durée des séjours ainsi que les informations relatives à la facturation et aux tarifs appliqués. D'autres informations administratives pourront être intégrées en fonction des besoins identifiés au cours de la conception.

Les deux applications seront hébergées sur des **serveurs Web distincts**, chacun étant associé à sa propre base de données. Cette séparation vise notamment à distinguer les données nécessaires à la gestion administrative des informations médicales sensibles.

2.1.2. Disponibilité et résilience des données

Compte tenu de la nature sensible des données traitées par la clinique, l'infrastructure devra prévoir des mécanismes permettant d'assurer leur disponibilité et leur protection contre les défaillances.

Les données des applications DPI et GAP devront faire l'objet d'une stratégie de sauvegarde et de protection adaptée afin de limiter les risques de perte de données en cas de panne matérielle, logicielle ou d'incident affectant l'infrastructure.

Une attention particulière devra être portée à la **réplication et à la redondance des données**. La solution technique permettant de répondre à cette exigence sera déterminée au cours de la phase de conception.

2.2. Services d'administration et d'authentification

2.2.1. Services d'infrastructure réseau

L'infrastructure devra disposer des services nécessaires à l'administration centralisée du réseau et des postes de travail.

Un serveur basé sur **Active Directory** assurera notamment la gestion centralisée des comptes utilisateurs et des politiques d'accès. Il intégrera les services **DNS et DHCP** nécessaires au fonctionnement du réseau.

Ces services seront déployés en double sur deux serveurs distincts afin d'assurer leur redondance, garantir la continuité de service et renforcer la sécurité de l'infrastructure. Les deux serveurs seront actifs en même temps et le basculement se fera automatiquement en cas de panne d'un des deux serveurs.

2.2.2. Authentification réseau

Un serveur **RADIUS** sera déployé afin de fournir un mécanisme d'authentification centralisé pour les accès au réseau.

Il sera notamment utilisé pour contrôler l'accès aux réseaux **Wi-Fi et Ethernet** de la clinique et permettre l'application de politiques d'accès en fonction des utilisateurs ou de leurs profils.

L'architecture devra également prévoir une séparation claire entre le réseau interne destiné au personnel et le réseau Wi-Fi invité destiné aux patients et visiteurs. Les utilisateurs invités ne devront pas pouvoir accéder aux ressources internes de la clinique.

2.3. Services de communication

La clinique devra disposer d'un service de **téléphonie sur IP (VoIP)** permettant les communications téléphoniques internes.

Un serveur **FreePBX** assurera la gestion du système de téléphonie. Des téléphones IP seront notamment installés dans les différentes salles de la clinique afin de permettre au personnel de communiquer entre les espaces de soins et les autres fonctions de l'établissement.

2.4. Services de partage et de stockage

Un serveur de fichiers sera mis en place afin de centraliser le stockage et le partage des fichiers nécessaires au fonctionnement de la clinique.

Les ressources seront organisées sous forme de **volumes ou espaces de partage accessibles sur le réseau**. Les accès à ces ressources seront contrôlés par des droits associés aux différentes catégories de personnel.

Cette organisation devra permettre de garantir que chaque utilisateur puisse accéder uniquement aux ressources correspondant à ses fonctions et à ses responsabilités, notamment afin de protéger les informations médicales et administratives.

2.5. Services de sécurité et de contrôle d’accès

La clinique devra disposer d’un système permettant de gérer la **vidéosurveillance et le contrôle des accès par badge**.

Un serveur dédié assurera la gestion de ces équipements et mettra à disposition une **interface Web** permettant aux utilisateurs autorisés de consulter les informations issues du système de vidéosurveillance ainsi que les événements associés au contrôle d’accès.

L'accès à cette interface devra être restreint aux personnes habilitées.

2.6. Services de sécurité réseau, pare-feu et accès distant

La sécurité des communications réseau sera assurée par une infrastructure reposant sur **deux serveurs physiques dédiés**, chacun exécutant un système d’exploitation permettant l’hébergement de **pfSense**.

Les deux instances pfSense auront pour rôle d'assurer les fonctions principales de **pare-feu et de routage** de l’infrastructure. Elles constitueront le point de contrôle des communications entre les différents réseaux internes ainsi qu’entre le réseau de la clinique et les réseaux externes.

Cette architecture à deux serveurs devra contribuer à la **résilience de la fonction de sécurité réseau**, afin qu'une défaillance d'un serveur ne compromette pas l'ensemble de la connectivité de la clinique. Le mécanisme permettant d'assurer cette redondance et, le cas échéant, le basculement entre les deux instances sera défini lors de la phase de conception.

L’infrastructure disposera de deux moyens de connexion à Internet : une **liaison fibre principale** et une **liaison satellitaire Starlink de secours**. La stratégie permettant d'exploiter ces deux connexions et d'assurer la continuité de la connectivité en cas d'indisponibilité de la liaison principale sera également définie au cours de la conception.

Les fonctions de sécurité réseau devront également intégrer un **service VPN** permettant d'établir des connexions distantes sécurisées vers l'infrastructure de la clinique. L'accès VPN devra être contrôlé et réservé aux utilisateurs ou administrateurs dûment autorisés.

L'ensemble de ces mécanismes devra contribuer à la protection du système d'information contre les accès non autorisés et les communications malveillantes, tout en maintenant la disponibilité des services nécessaires au fonctionnement de la clinique.

2.7. Continuité électrique

Afin de garantir la continuité de fonctionnement des équipements critiques de l’infrastructure réseau, un **onduleur (UPS)** devra être mis en place pour assurer leur alimentation électrique en cas de coupure ou de perturbation du réseau électrique.

L’onduleur devra notamment protéger les équipements réseau critiques tels que les serveurs physiques hébergeant pfSense, les équipements de commutation et les autres composants nécessaires au maintien de la connectivité de la clinique.

L’onduleur devra disposer d’une **interface réseau et d’une adresse IP**, permettant sa communication avec le système d’information et sa supervision à distance. Les informations relatives à son état de fonctionnement, à son alimentation et aux éventuelles anomalies devront être accessibles depuis la plateforme de supervision **Zabbix**.

Cette supervision devra permettre de détecter rapidement les événements affectant l’alimentation électrique, notamment une coupure du secteur, un fonctionnement sur batterie ou une anomalie de l’onduleur, afin de faciliter la prise en charge des incidents.

Le dimensionnement de l’onduleur et la durée d’autonomie nécessaire seront déterminés lors de la phase de conception en fonction de la puissance des équipements à alimenter et des objectifs de continuité de service.

2.8. Sauvegarde

Un serveur dédié à la sauvegarde sera mis en place afin de protéger les données et les éléments importants de l’infrastructure informatique.

La stratégie de sauvegarde devra être automatisée et intégrer des mécanismes permettant de vérifier la disponibilité de l’espace de stockage ainsi que le bon déroulement des opérations de sauvegarde.

L’intégrité et la validité des sauvegardes devront également pouvoir être contrôlées afin de s'assurer qu'elles puissent être utilisées en cas de besoin.

Le périmètre exact des données et systèmes devant être sauvegardés sera précisé au cours de la phase de conception.

2.9. Supervision de l’infrastructure

Une solution de supervision basée sur **Zabbix** sera mise en place afin de surveiller l’état de fonctionnement des équipements composant l’infrastructure réseau.

La supervision portera notamment sur les différents équipements du LAN, tels que les commutateurs réseau et autres équipements d’infrastructure.

L’objectif est de disposer d’une vision centralisée de l’état des équipements et de détecter rapidement leur indisponibilité ou l'apparition d'anomalies. Le système devra permettre de générer des alertes lorsqu’un équipement supervisé devient indisponible ou présente un comportement nécessitant une intervention et journaliser des logs.

La supervision aura ainsi pour objectif de faciliter la maintenance de l’infrastructure et de réduire le temps nécessaire à la détection des incidents.

3. Définition des besoins de communication et d'échanges de données

Cette section fixe toutes les obligations de connexions matérielles, configurations réseaux, ainsi que la totalité des échanges de données, que ce soit à l'intérieur ou à l'extérieur de la clinique.

3.1. Infrastructure Réseau Locale (LAN)

- Installation physique :
    - Commutateurs (switchs) en cluster de 2 pour assurer la redondance
    - Firewall avec routage et de passerelles (gateway) conformes aux normes Ethernet (IEEE 802.3x) pour transporter les données.
    - Chaque tente doit-être équipée de prise réseau RF45.

- Déployer le Wi-Fi sous toutes les tentes pour permettre au personnel d'aller de tente en tente avec leurs tablettes, PC portables et permettre de connecter certains dispositifs médicaux connectés (IoMT) sans être déconnecté. Il y aura 3 réseaux Wi-Fi différents pour le médical, l'administration et les invités. Le Wi-Fi invité doit être isolé du réseau et donner l'accès à internet.

3.2. Téléphonie et Communications

- Installation d'un serveur de téléphonie IP-PBX local qui gère les appels vocaux vie internet (VoIP). Les communications vocales internes entre l'accueil, les salles de soins, les chambres et le bureau administratif doivent fonctionner de manière 100% autonome, même en cas d'isolement d'Internet.

3.3. Interconnexion de Sites (Réseau Étendu - WAN)

- Établir un VPN sécurisé de site à site vers des hôpitaux ou d'autres structures médicales externes afin de permettre l'échange de données médicales. Il y aura donc une connexion Internet, mais l'accès à Internet doit être bloqué dans les 2 sens. Seule la connexion VPN avec l'autre hôpital sera mise en place avec consultation uniquement des données médicales et rien d'autre.
- Redondance de la connexion vers Internet (Double WAN) via des opérateurs et technologies distinctes (ex: liaison filaire locale + secours satellite ou 4G/5G) avec basculement automatique et transparent.

4. Définition des Besoins en Termes de Sécurisation

Cette section regroupe l'ensemble des exigences liées à la cyberdéfense, à la protection des données sensibles et à la résilience face aux pannes ou attaques.

4.1. Contrôle d'Accès Réseau (Architecture 802.1X)

- Authentification RADIUS : Déploiement obligatoire de la norme IEEE 802.1X. Aucun équipement (PC fix, ordinateur portable, équipement médical connecté IoT) ne doit pouvoir transiter sur les switchs ou le Wi-Fi sans s'être préalablement authentifié de manière sécurisée auprès du serveur RADIUS.

4.2. Segmentation Réseau Étanche (Architecture VLANs)

Pour isoler les flux et appliquer le principe du moindre privilège, le réseau doit être découpé via une architecture de VLANs stricte
VLANs minimum :

- 1 VLAN Administratif : dédié uniquement aux données de gestion administrative des patients.
- 1 VLAN Données Médicales (Séparé en 2) :Dédié à l'application du tableau des patients (DPI) et dédié aux fichiers sensibles à protéger (imagerie, examens).
- 1 VLAN de Direction : Segment privilégié à partir duquel les postes de la direction ont explicitement l'autorisation technique de communiquer et d'accéder aux deux VLANs précédents (Administratif et Médical).

4.3. Développement Logiciel Sécurisé et Gestion des Accès Physiques

Tous les développements spécifiques liés à la sécurité physique de la clinique (gestion des badges d'accès RFID pour l'accès aux tentes de soins & administratif) doivent respecter deux exigences logicielles :

- Gestion des badges d’accès : Création d’une page web où la direction peut changer les droits et assignations des badges.
- Sécurité renforcée : Le code doit valider les droits d'accès selon le rôle de l'utilisateur (médical, administratif, direction).
- Sécurité en Mode Dégradé : En cas de défaillance réseau ou de coupure avec le serveur central, le code des lecteurs de badges doit basculer de manière transparente en mode autonome (utilisation d'une mémoire cache locale des derniers badges valides ou possibilité de déverrouillage via la saisie d'un code PIN d'urgence sur un pavé numérique avec une batterie).

4.4. Gestion des Risques, Tests et Cadre de Travail DevOps

- Méthodologie Agile et CI/CD : L'intégralité du projet (configurations réseau, scripts, codes applicatifs des badges) doit être développée de manière itérative, partagée sur un environnement style GitHub/GitLab et Trello, et déployée de façons automatisé avec un environnement de Développement (Dev) et un environnement de Production (Prod).
- Tests de Pénétration (Pentests) : Avant la mise en service, on devra réaliser des tests d'intrusion pour valider l'étanchéité de notre infrastructure informatique et réseau.
- Procédures : Rédaction de fiches réflexes techniques et de mécanismes de défense immédiats pour contrer les pannes matérielles ou les attaques. Rédaction de procédure pour les utiliser les pages web développées (Gestion badge, vidéosurveillance, DPI et GAP).
- Veille : Pour enrichir ces politiques de sécurité, on devra contacter des DSI de Centres Hospitaliers afin d'intégrer au cahier des charges les dernières pratiques concrètes de cyberdéfense face aux ransomwares.

5. Tableau d’analyse des risques

Risque	Niveau de dangerosité	Réponse au risque	Périodicité de test
Coupure électrique	Critique	Mise en place d’un onduleur (UPS) pour maintenir temporairement l’alimentation des équipements critiques. L’onduleur est supervisé par Zabbix.	2 à 3 fois par mois
Panne de la connexion Internet principale (fibre)	Élevée	Mise en place d’une seconde connexion via Starlink et d’un mécanisme de basculement afin de maintenir la connectivité externe.	1 fois par mois
Panne d’un équipement réseau	Élevée	Supervision des équipements par Zabbix afin de détecter rapidement les pannes. Prévoir du matériel de remplacement et des procédures de rétablissement.	1 fois par mois
Panne d’un serveur pfSense	Critique	Mise en place de deux serveurs physiques hébergeant pfSense afin d’assurer la redondance du pare-feu et du routage.	2 fois par semestre
Panne d’un serveur DPI ou GAP	Critique	Mise en place de sauvegardes et étude d’une solution de réplication ou de redondance des bases de données afin de limiter les interruptions et les pertes de données.	1 fois par semaine
Perte ou corruption de données	Critique	Mise en place d’un serveur de sauvegarde avec sauvegardes automatisées et vérification de leur intégrité.	1 fois par semaine
Intrusion	Critique	Segmentation réseau par VLAN, authentification 802.1X/RADIUS, gestion des droits utilisateurs, sauvegardes et réalisation de tests de pénétration.	2 fois par semestre
Accès non autorisé aux données médicales	Critique	Segmentation des réseaux, contrôle des droits d’accès et application du principe du moindre privilège.	2 fois par semestre

Accès d'un invité aux ressources internes	Élevée	Mise en place d'un réseau Wi-Fi invité isolé des réseaux internes et limité à l'accès Internet.	2 fois par semestre
Attaque des applications Web DPI/GAP	Élevée	Développement sécurisé, contrôle des droits d'accès, séparation des bases de données et réalisation de tests de pénétration.	1 fois par mois
Défaillance du système de contrôle d'accès par badge	Élevée	Mise en place d'un mode dégradé permettant aux lecteurs de badges de fonctionner de manière autonome en cas de perte du réseau ou du serveur central.	1 fois par mois
Interception des communications avec un établissement externe	Critique	Utilisation d'un VPN site-à-site sécurisé et filtrage des communications par le pare-feu afin de limiter les flux au strict nécessaire.	2 fois par semestre
Déni de service (DoS/DDoS)	Élevée	Filtrage des communications par pfSense et mise en place de mécanismes permettant de détecter les indisponibilités.	3 fois par semestre
Vol ou accès physique non autorisé aux zones	Élevée	Contrôle d'accès par badge RFID et vidéosurveillance des zones sensibles.	3 fois par semestre

6. Répartition des tâches au sein du groupe

Commun : Création de l'infrastructure réseau, plan d'adressage, veille informatique, tests de pénétration et de panne.

Florian LATTARD - Création d'un hyperviseur pour héberger les VM. Création et configuration du Firewall et du VPN. Création d'un serveur avec scripts de sauvegarde, création et configuration du serveur de supervision, faire un serveur et créer des partages de fichiers pour chaque service du site.

Pierre ENGELENDER - Création d'un serveur avec AD, DNS et DHCP. Création d'un serveur d'authentification Radius. Création d'un serveur Web DPI pour héberger le site pour les médecins (accès fiche médical patients). Création du serveur Web GAP où le personnel de l'administration gère quel patient est allé dans quelle salle, durée du séjour, prix etc… Création des pages Web associées aux serveurs. Documentation utilisateur pour utiliser les pages Web.

Aminata YABRE - Création d'un serveur de sécurité pour la vidéosurveillance et le contrôle d'accès par badge. Création page Web pour consulter et modifier. Création serveur pour les communications VoIP. Documentation utilisateur pour utiliser la page Web. du site de sécurité.

Bastien LAURENT - Création d'un serveur triple A Radius (Authentication, authorization, accounting) avec gestion des utilisateurs, Mise en place des lecteurs de badges pour l'accès au site, avec page web associé pour la gestion. Documentation associée.

Emile FREZZA - Création d'un serveur Zabbix afin de superviser l'infrastructure. Contacter des DSI hôpitaux afin d'avoir plus d'informations sur la veille informatique. Analyse du coût du projet. Création d'un serveur Web DPI pour héberger le site pour les médecins (accès fiche médical patients). Création du serveur Web GAP où le personnel de l'administration gère quel patient est allé dans quelle salle, durée du séjour, prix etc… Création des pages Web associées aux serveurs. Création d'un guide utilisateur.

Note : L'IA générative a été utilisée pour corriger les fautes et reformuler certaines phrases. Tout le reste, la phase de réflexion, les propositions techniques, etc sont le fruit du travail humain.